

CHAPTER 5: BUSINESS PLAN AND MODEL

This chapter outlines the strategic roadmap for Bléum Nails By Micah, detailing the business objectives, local marketing strategies, and the operational model that ensures the salon's long-term viability through digital automation. It bridges the gap between technical software development and professional service delivery by focusing on how digital infrastructure supports the salon's growth and sustainability.

5.1 Business Plan

5.1.1 Executive Summary

Bléum Nails By Micah is a specialized, home-based nail salon currently transitioning from inefficient, manual, paper-based operations to a high-performance digital framework. The primary goal of this business plan is to utilize the new appointment system to eliminate critical scheduling errors and prevent technician fatigue by strictly enforcing a three-client daily limit through an automated algorithm. By incorporating secure QRPh payments and a professional, user-friendly Client Dashboard, the salon aims to provide a premium, 24/7 accessible experience that builds long-term client trust. Furthermore, the salon ensures absolute data privacy by adhering to Republic Act No. 10173 (Data Privacy Act of 2012), providing clients with a secure environment for their personal and medical information.

5.1.2 General Company Description

Located in Caloocan City, Bléum Nails By Micah is a professional micro-enterprise that specializes in high-quality, specialized nail technology, including Gel overlays, Soft gel extensions, and BIAB (Builder in a Bottle). The business mission is to offer professional-grade wellness services supported by an organized and efficient digital interface. By centralizing the service calendar, client records, and transaction history into a single web-based platform, the salon operates as a modern, technology-driven wellness provider. This digital transformation prioritizes both the physical well-being of the technician and the convenience of the modern customer, ensuring that the salon remains competitive in an increasingly digital local market.

5.1.3 Products and Services Offered

The salon provides a specialized range of premium wellness and aesthetic services, which are now fully integrated into a centralized digital management platform to enhance the overall customer journey:

- **Core Services:** The salon offers high-end nail applications, specifically focusing on Builder in a Bottle (BIAB), Gel overlays, intricate soft gel extensions and etc. That requires precision and scheduled time blocks.
- **Digital Booking Interface:** A 24/7 accessible web-based platform allows clients to view real-time availability and secure appointment slots without the need for manual, back-and-forth messaging.

- **Secure Payment Handling:** The system features an integrated QRPh localized payment display and automated digital receipt generation, ensuring that every transaction is professionally recorded and transparent.
- **Ethical Safety Monitoring:** A dedicated Allergy Tracking module is used to screen clients for chemical sensitivities before service application, ensuring a higher standard of ethical care and safety in compliance with health standards.

5.1.4 Marketing Plan

The marketing plan is strategically tailored to the salon's target demographic in Caloocan City, specifically focusing on mobile-first consumers who value operational efficiency and brand legitimacy.

- **Market Need:** The salon directly fills a technical gap in the local micro-enterprise market by providing home-based services that offer the same level of digital security and booking convenience as large, commercial mall-based salons.
- **Competitive Edge:** Bléum Nails By Micah differentiates itself by offering a highly personalized and private environment supported by professional grade features such as real-time capacity management, specialized allergy tracking, and secure localized digital payments.

5.1.5 Marketing Strategy

To build brand authority and community trust, the salon utilizes a multi-channel digital strategy designed to maintain constant engagement with its audience:

- **Social Media Integration:** The digital booking platform is directly linked to the salon's established Facebook and Instagram profiles, creating a unified and professional brand experience across all touchpoints.
- **Cross-Device Accessibility:** By strictly adhering to W3C standards, the salon ensures that its digital presence is functional and visually consistent on every device a client might use, from smartphones and tablets to desktop computers.
- **Client Retention and Trust:** The use of automated verification codes, instant booking confirmations, and digital receipts provides a level of responsiveness that encourages repeat business and positive word of mouth referrals within the community.

5.2 Business Model

The business model for Bléum Nails By Micah is built on an Efficiency-Driven Framework designed to maximize revenue while minimizing the administrative labor previously required for manual coordination.

- **Revenue Streams:** Primary income is generated directly through service fees for specialized nail applications. The digital system acts as a force multiplier by preventing lost revenue typically caused by double-booking errors, manual communication bottlenecks, or scheduling abandonment.

- **Operational Efficiency:** The Capacity-Limiting Algorithm ensures a sustainable and consistent revenue stream by automatically filling the three available daily slots without the risk of overbooking or technician burnout.
- **Cost Reduction:** By automating the scheduling, payment verification, and record-keeping processes, the salon significantly reduces the administrative overhead of manual coordination, allowing the technician to focus entirely on service delivery

5.3 Intellectual Property (IP) Reports

The technical assets supporting the salon's daily operations are managed to ensure long-term security, legal compliance, and technical integrity:

- **Custom Software Assets:** The Bléum Nails Appointment System, including the custom-built FastAPI backend and normalized MySQL database structure, is a proprietary tool developed specifically to meet the unique operational needs of this salon.
- **Legal and Privacy Compliance:** The business logic for handling personal client information is strictly aligned with Republic Act No. 10173 (Data Privacy Act), protecting both the salon and its clients from potential data privacy risks and legal liabilities.
- **Standardization and Longevity:** By basing the digital infrastructure on international benchmarks like ISO/IEC 25010 and W3C Web Standards, the salon ensures that its system is built on a globally recognized, secure, and professional foundation that can be maintained over time.

REFERENCES

Desruisseaux, B. (Ed.). (2009). *RFC 5545: Internet Calendaring and Scheduling Core Object Specification (iCalendar)*. Internet Engineering Task Force (IETF). <https://datatracker.ietf.org/doc/html/rfc5545>

International Organization for Standardization. (2011). *ISO/IEC 25010:2011 Systems and software engineering — Systems and software Quality Requirements and Evaluation (SQuaRE) — System and software quality models*. <https://www.iso.org/standard/35733.html>

National Privacy Commission (Philippines). (n.d.). *Republic Act No. 10173 (Data Privacy Act of 2012)*. <https://privacy.gov.ph/data-privacy-act/>

OWASP Foundation. (2024). *OWASP Application Security Verification Standard (ASVS) v5.0*. <https://owasp.org/www-project-application-security-verification-standard/>

PCI Security Standards Council. (2025). *Payment Card Industry Data Security Standard (PCI DSS) v4.0*. https://www.pcisecuritystandards.org/document_library?category=pcidss&document=pci_dss

World Wide Web Consortium (W3C). (n.d.). *Web standards*. <https://www.w3.org/standards/>

APPENDICES

APPENDIX A: ISO/IEC 25010:2011 – Systems and Software Quality Requirements

This is an international standard that defines a comprehensive framework for evaluating software quality. It establishes a quality model composed of eight characteristics: functional suitability, performance efficiency, compatibility, usability, reliability, security, maintainability, and portability. The purpose of this standard is to ensure that software systems meet user requirements, perform efficiently, and maintain long-term reliability and security. In this project, the standard serves as the primary benchmark for assessing the overall quality of the Bléum Nails By Micah Appointment System, ensuring that it delivers accurate scheduling, a user-friendly interface, optimal performance, and dependable functionality. This appendix provides the reference framework used to evaluate the system's software quality characteristics as outlined in Section 1.7 of this document. The standard defines what quality means for software products and provides consistent terminology for specifying, measuring, and evaluating system quality.

Application to Bléum Nails By Micah:

The five primary constraints identified in Chapter 1.6 of this document are directly mapped to the ISO/IEC 25010 characteristics as follows:

Project Constraint	ISO/IEC 25010 Characteristics	Sub-characteristics Applied
User Satisfaction Score	Usability	Appropriateness recognizability, Learnability, Operability, User error protection
Task Success Rate	Functionality Sustainability	Functional completeness, Functional correctness
Page Load Speed	Performance Efficiency	Time behaviour, Resource utilization
System Availability	Reliability	Availability, Fault tolerance, Recoverability
Code Simplicity Score	Maintainability	Modularity, Reusability, Analysability, Modifiability

The Bleum Nails By Micah Appointment System has been developed and evaluated against the ISO/IEC 25010:2011 standard. The selection of Design Alternative 2 (Decoupled Full-Stack Architecture) was based on normalized scoring across all five quality characteristics, with usability and functionality weighted at 25% and 22.5% respectively, as documented in Chapter 3.2 of this report.

APPENDIX B: Republic Act No. 10173 – Data Privacy Act of 2012 (Philippines)

Republic Act No. 10173, also known as the Data Privacy Act of 2012, is the primary law governing the protection of personal information in the Philippines. It establishes guidelines for the collection, processing, storage, and security of sensitive data in information and communications systems. The law aims to safeguard individual privacy while ensuring the free flow of information to promote innovation and economic growth. Its purpose is to protect data subjects from unauthorized access, misuse, and breaches. In the context of this project, the standard ensures that all client information—such as names, contact details, and transaction records—is securely handled through encryption, authentication mechanisms, and role-based access control. This appendix demonstrates strict technical compliance with the Philippine Data Privacy Act, as required in Section 1.7 of this document. The law is the primary legislation protecting individual personal information in information and communications systems in the Philippines.

General Data Privacy Principles:

The DPA establishes three core principles that govern all personal data processing:

Principle	Description	System Implementation
Transparency	Data subjects must be fully informed how their personal information will be processed	Sign-up form includes Privacy Policy consent checkbox; system provides clear notice of data collection purposes
Legitimate Purpose	Processing of personal data must be for a declared, specified, and lawful purpose	Data collected only for appointment confirmation, allergy screening, and service delivery
Proportionality	Collection and processing must be limited to what is necessary for the specified purpose	Only name, email, phone number, and allergy information collected; no excessive data gathering

Rights of Data Subjects:

The DPA grants the following rights to individuals whose data is processed:

Rights	Description	System Implementation
Right to be Informed	Know if personal information is being processed and the extent of processing	Privacy Policy accessible; data collection notice displayed at registration
Right to Object	Object to processing for certain circumstances (e.g., direct marketing)	Account deletion option available; opt-out mechanisms implemented
Right to Access	Access personal information held by the data controller	Client Dashboard displays user's own data; data export functionality

Right to Rectification	Request corrections to inaccurate or incomplete data	Profile editing features allow users to update their information
Right to Erasure/locking	Request deletion of data when unlawfully processed or no longer needed	Account deletion permanently removes user data from database
Right to Data Portability	Obtain data copy in electronic format for transfer to another provider	JSON export of user data available upon request

Security Measures Implemented:

DPA Security Requirement	Technical Implementation
Organizational Measures	Data protection policies documented; staff training on privacy practices
Physical Measures	Secure server hosting; controlled database access
Technical Measures	Password hashing (bcrypt); data encryption; HTTPS/TLS for all transmissions; Role-Based Access Control (RBAC)

The Bleum Nails By Micah Appointment System is fully compliant with Republic Act No. 10173. All personal data collected (names, contact numbers, email addresses, and allergy records) is processed in accordance with the principles of transparency, legitimate purpose, and proportionality. The salon owner acts as the Personal Information Controller, with appropriate security measures in place to protect client data.

APPENDIX C: W3C Web Design and Applications Standards

The W3C Web Design and Applications Standards are international guidelines developed to ensure consistency, accessibility, and interoperability across web platforms. These standards include HTML5 for content structure, CSS3 for presentation and layout, and JavaScript for interactivity and dynamic functionality. The core objectives of these standards are to facilitate access for all users, ensure compatibility across various browsers, and promote designs that adapt to different devices or screen sizes. By implementing these standards, the Bléum Nails By Micah Appointment System is able to provide a consistent, accessible, and visually appealing experience to the user, regardless of whether they are interacting with the platform via a desktop, a tablet, or a mobile device. This appendix documents compliance with World Wide Web Consortium (W3C) standards for web development, ensuring cross-browser compatibility, accessibility, and professional presentation as specified in Section 1.7 of this document.

Core Standards Implemented:

Standard	Version	Purpose in System
HTML5	W3C Recommendation	Structural markup for all web pages; semantic elements (header, nav, main, footer)
CSS3	W3C Candidate Recommendation	Structural markup for all web pages; semantic elements (header, nav, main, footer)
Javascript/ECMAScript	ES6 (ECMAScript 2015)	Client-side interactivity, API communication, dynamic content updates

The Bleum Nails By Micah Appointment System has been developed in accordance with W3C HTML5, CSS3, and ES6 standards. The frontend code has been validated using the W3C Markup Validation Service. The responsive design ensures consistent functionality and visual presentation across Google Chrome, Mozilla Firefox, Safari, and mobile browsers (iOS Safari, Android Chrome).

APPENDIX D: OWASP Application Security Verification Standard (ASVS) Level 1

The OWASP Application Security Verification Standard (ASVS) Level 1 provides a framework for securing web applications, particularly those accessible to the public. It outlines essential security controls, including secure authentication, input validation, session management, access control, and protection against common vulnerabilities such as SQL injection and cross-site scripting. The purpose of this standard is to help developers design, build, and maintain secure applications that protect sensitive data and prevent cyber threats. In this project, OWASP ASVS Level 1 ensures that the system implements secure login procedures, encrypted credentials, and robust validation mechanisms to safeguard client and administrative information. This appendix documents the implementation of OWASP ASVS Level 1 security controls for the Bleum Nails By Micah system. Level 1 is the baseline level of verification and is appropriate for low-risk applications where the primary security concern is protecting against common vulnerabilities.

ASVS Level 1 Requirements:

ASVS Category	ASVS ID	Requirement	System Implementation
Authentication	2.2.6	No clear text passwords	Passwords hashed using bcrypt
Authentication	2.2.7	No username enumeration	Generic error messages ("Invalid credentials")

Session Management	3.4.1	Cookie Secure flag	Session cookies marked Secure (HTTPS only)
Session Management	3.4.2	Cookie HttpOnly flag	Session cookies marked HttpOnly
Access Control	4.1.1	Access control enforced server-side	All API endpoints verify user permissions
Input Validation	5.3.4	Parameterized queries for SQL injection	SQLModel/SQLAlchemy with parameterized queries

The Bleum Nails By Micah Appointment System meets all applicable OWASP ASVS Level 1 requirements. Regular security testing is recommended to maintain compliance as the application evolves.

APPENDIX E: iCalendar (RFC 5545) – Internet Calendaring and Scheduling Core Object Specification

RFC 5545, commonly known as the iCalendar standard, defines a universal format for representing and exchanging scheduling and calendaring information. It enables systems to create, share, and synchronize events using standardized data structures compatible with popular calendar platforms such as Google Calendar and Microsoft Outlook. The purpose of this specification is to promote interoperability and efficient scheduling across digital environments. Within this project, the iCalendar standard supports the management of appointment schedules, enabling accurate booking, automated reminders, and potential integration with external calendar applications. This appendix documents the implementation of RFC 5545 for representing and exchanging calendaring and scheduling information, as referenced in Section 1.7 of this document.

APPENDIX F: Payment Card Industry Data Security Standard (PCI DSS) – Third-Party Integration

The Payment Card Industry Data Security Standard (PCI DSS) is a globally recognized framework that establishes security requirements for handling payment-related information. The main objective of the PCI DSS is to safeguard money transfer activities by ensuring that data is transmitted securely, access is granted only through strong controls, encryption is used at various stages, and regular monitoring of systems is carried out. Although the Bléum Nails By Micah Appointment System does not store cardholder data directly, it adheres to PCI DSS principles through secure third-party integrations, such as QRPh payments and digital receipt verification, ensuring the confidentiality and integrity of financial transactions.

Compliance Approach:

The Bleum Nails By Micah system follows a PCI DSS compliance through third-party integration approach. Instead of handling card data directly, the system integrates with a PCI-compliant payment provider (PayMongo/QRPh) and never touches sensitive cardholder data.

PCI DSS Requirements Mapping:

PCI DSS Requirements	System Implementation	Status
Requirement 1: Install and maintain firewall configuration	Web application hosted behind firewall; only necessary ports open	Compliant
Requirement 2: No vendor-supplied defaults	Default passwords changed; secure configuration applied	Compliant
Requirement 3: Protect stored cardholder data	N/A - System does not store cardholder data	Not Applicable
Requirement 4: Encrypt transmission over public networks	TLS 1.3 for all communications; secure API calls to payment provider	Compliant
Requirement 5: Protect against malware	Server anti-malware protection; regular security updates	Compliant
Requirement 6: Develop secure applications	Secure coding practices (OWASP); input validation; parameterized queries	Compliant
Requirement 7: Restrict access to cardholder data	N/A - No cardholder data stored	Not Applicable
Requirement 8: Identify and authenticate access	Strong authentication (bcrypt hashed passwords); session management	Compliant
Requirement 9: Restrict physical access	Hosting provider implements physical security controls	Compliant
Requirement 10: Track and monitor access	System logs authentication attempts and administrative actions	Compliant
Requirement 11: Regular testing	Security testing performed; vulnerability scans	Compliant
Requirement 12: Maintain security policy	Information security policy documented	Compliant

QRPh Payment Integration Security Measures:

Security Control	Implementation
No card data storage	System never stores PAN, CVV, or expiry dates
Payment tokenization	Payment provider returns tokens, not card numbers
Secure API communication	All payment API calls over TLS 1.3
Webhook verification	Payment provider webhooks verified using signatures
Receipt data minimization	Receipts show only last 4 digits (if any), not full PAN
Session separation	Payment flow handled by provider; no card data enters system

The Bleum Nails By Micah Appointment System does not store, process, or transmit cardholder data. All payment transactions are handled by a PCI DSS Level 1 certified third-party payment provider (QRPh/PayMongo). The system only receives payment confirmation webhooks and generates receipts based on transaction status. This approach significantly reduces the salon's PCI DSS compliance scope.